WawID

# Deployment plan

High-availability infrastructure hosted in Senegalese datacenters, backups and disaster recovery

Version 1.0 · 19 October 2026
WAW Telecom · Working document — demonstration data

# Contents

Reading this plan
Summary
1. Objectives and requirements
2. Target topology
3. Backup strategy
4. High availability and disaster recovery
5. Security and compliance
6. Deployment phases
7. Environments
8. Operations
9. Bill of materials per site
10. Risks and mitigations
11. Existing, target and to be developed

This plan describes how WawID moves from the current demonstrator to **sovereign, high-availability** national operations: two active data centers in Senegal, a third backup site (vault), local servers at each border post, a backup strategy, failover and recovery procedures, deployment phases, operations and risks. It is intended for WAW Telecom, the DPAF, Sénégal Numérique, the hosting providers, the DGCPT and the integrators.

It complements `docs/ARCHITECTURE.md` (target national architecture) and the pages *Installation guide — Senegal* (installation of posts, acceptance, go-live), *Deployment and configuration* (demonstrator, variables, NFC bridge) and *Security, personal data and compliance*. The *User guide by profile* describes what users experience in degraded mode and during a failover.

## Reading this plan

| Label | Meaning |
|---|---|
| **Existing** | Works today in the demonstrator (code in the repository). |
| **Target** | Architecture selected for national production; it remains to be built. |
| **To be developed** | Requires software development absent from the current code. |
| **Recommendation** | Advised choice; it commits no party until it has been decided. |
| **To be checked** | Fact, certification, capacity or legal point to confirm with the competent party before any decision. |

This plan contains no prices, no contractual service levels and no dates: amounts, commitments and schedules will result from consultations and agreements. The durations given are **indicative**.

## Summary

| Decision | Recommendation |
|---|---|
| Hosting | In Senegal only, with no foreign cloud for personal data |
| Site A (primary) | National data center in Diamniadio (State-owned, operated by Sénégal Numérique SA) |
| Site B (active secondary) | Tier III-certified commercial data center on a separate site and power grid; preferred option: Sonatel (Orange) in Rufisque, alternative: Yas (formerly Tigo) in Diamniadio |
| Site C (vault) | Separate secure site, outside the Dakar–Diamniadio area if possible, receiving immutable encrypted copies and offline copies |
| Operating mode | Active-active for stateless tiers (web, API); database in primary/standby with synchronous replication A → B; asynchronous replication to C |
| Border posts | Local cluster of two servers per post, with a copy of the lists and a local decision engine; checks continue even if both central sites are unreachable |
| Objectives | Central availability of 99.95% or more; RPO 0 within a site; RPO ≤ 5 min and RTO ≤ 1 h if a site is lost |
| Backup | 3-2-1-1-0 rule, restoration tested every quarter |

| Decision | Recommendation |
|---|---|
| Netlify demonstrator | Kept for demonstrations and training, without any real personal data |

# 1. Objectives and requirements

## Sovereignty

- **Data and keys in Senegal**: nominative, biometric, travel and financial data, as well as the cryptographic keys that protect it, are hosted and managed on national territory, in accordance with Law No. 2008-12 of 25 January 2008 on the protection of personal data and under the supervision of the CDP. The exact regime (declaration or authorization) is **To be checked** with the CDP.
- **No foreign cloud** for personal data. An encrypted copy abroad would require explicit authorization from the CDP and the State; it is **not recommended**.
- **Key control**: signing and encryption keys are generated and kept in HSMs located in sites A and B, under the control of the State (documented key ceremonies).
- **Reversibility**: the State retains ownership of the data and code; export formats (SQL, objects, audit log) are documented.

## Availability and recovery objectives

The values below take up and refine those of `docs/ARCHITECTURE.md`. They are **design objectives**, not contractual commitments.

| Indicator | Objective | Remark |
|---|---|---|
| Availability of central services | 99.95% or more per year | At most about 4 h 20 min of unplanned downtime per year |
| Data loss within a site (server or rack failure) | RPO 0 | Synchronous replication between nodes |
| Loss of a central site | RPO ≤ 5 min (0 targeted while synchronous replication A → B is healthy); RTO ≤ 1 h | Failover to the other central site |
| Simultaneous loss of both central sites | RPO according to the last copy received by site C; RTO to be defined (rebuild) | Posts continue checks in offline mode during the rebuild |
| Checking capacity at the post | 100%, including without a link to the central system | Post server (To be developed) |
| Synchronization of lists to posts | Under one minute | Objective from `docs/ARCHITECTURE.md` |
| Failover tests | At least twice a year | See section 4 |

## Continuity of checks at posts

Border control must never depend on the availability of the central system. Each post has a **post server** (two-node cluster) that runs the same decision engine as the central system

( `public/shared/engine.js` ), keeps an encrypted copy of the watchlists and queues crossings until the link returns ("store and forward"). This mode is **To be developed**: the demonstrator has no offline mode.

### Capacity

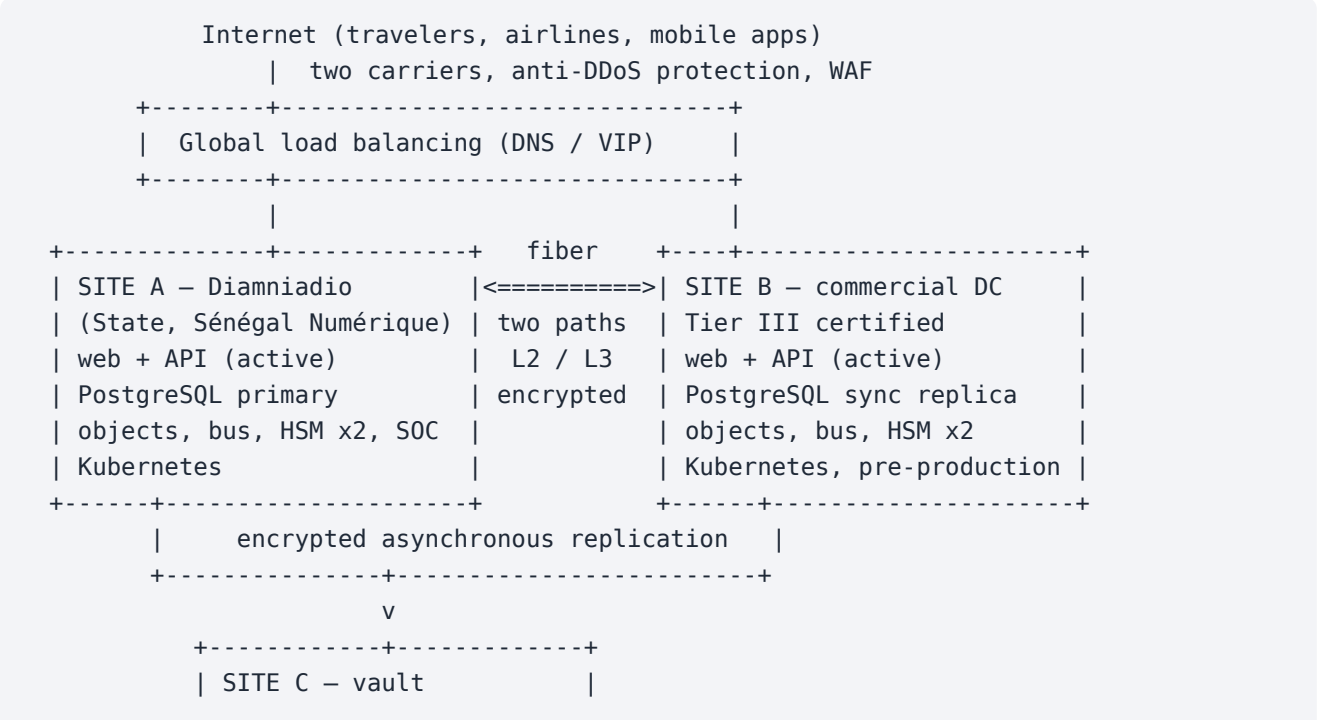
Sizing is based on the assumptions of `docs/ARCHITECTURE.md` , to be confirmed with the DPAF and with AIBD and ANACIM traffic statistics.

| Indicator | Estimate | Target sizing (×5) |
|---|---|---|
| Annual crossings, all posts | ~6 million | 30 million |
| AIBD peak | ~3,000 travelers/hour | 15,000/h |
| Checking transactions (national peak) | ~2/s | 10/s sustained, 50/s burst |
| List queries | ~10/s | 50/s |
| e-Visa applications | ~300,000/year | 1.5 million/year |
| Biometric database | ~10 million people after 5 years | 50 million |
| Posts, counters, eGates | 6 posts, ~60 counters, ~20 eGates | 60 posts, 600 counters, 200 eGates |
| Retention | 5 years (configurable) | ~150 million crossings |

Each central site must be able to carry **alone** 100% of the peak load: in active-active, each site therefore runs at no more than 50% of its capacity in normal conditions.

## 2. Target topology

### Overview



```
           | immutable copies,        |
           | offline copies           |
           +--------------------------+
        MPLS/VPN (carrier 1) + 4G/VSAT (carrier 2)
                        |
  +------+------+------+------+------+------+
  | AIBD | PDK  | ZIG  | ROS  | KID  | KAR  |   post server (2 nodes)
  +------+------+------+------+------+------+   counters, eGates, kiosks
```

## Choice of sites

The information below comes from public sources (trade press, data center directories). All of it must be confirmed by the operators during the consultation.

| Data center | Operator | Public facts | Status |
|---|---|---|---|
| National data center in Diamniadio | State, operated by Sénégal Numérique SA (formerly ADIE) | Inaugurated in June 2021; about 1,000 m² of technical rooms; 1.4 MW; presented as "Tier III type" | No Uptime Institute certification publicly confirmed: **To be checked** |
| Yas (formerly Tigo, Sen Connect) Diamniadio | Commercial operator | Uptime Institute Tier III certified (2017), commercial colocation | Nature (design or constructed facility) and validity of the certification **To be checked** |
| Sonatel (Orange) Rufisque | Commercial operator | Announced as Tier III ("Tier 3+"); second data hall added; expansion (phase 3) reported in 2025 by a single press source; announced proximity to the 2Africa cable landing | Certification, capacity and expansion **To be checked** |
| Free Sénégal Diamniadio | Commercial operator | Designed to the Tier III level | Not certified according to available information |
| PAIX Dakar, Onix | Colocation operators | Listed in data center directories | Characteristics **To be checked** |

### Site A — primary (Recommendation)

The **national data center in Diamniadio** is recommended as the primary site: sovereign State hosting, operated by Sénégal Numérique, consistent with the doctrine on sovereign government files. Points to confirm in the agreement with Sénégal Numérique: available capacity (floor space, power, cooling), actual redundancy level, physical security, access for WAW Telecom teams, available carrier connections, HSM colocation conditions, service levels. No commitment exists to date.

### Site B — active secondary (Recommendation)

Site B must be a **Tier III-certified** data center, on a **separate physical site** fed by a **separate electrical substation**, connected through fiber paths different from those of site A, while remaining close enough for synchronous replication (latency in the order of one millisecond).

| Criterion | Sonatel (Orange) Rufisque | Yas (formerly Tigo) Diamniadio |
|---|---|---|
| Geographic separation from site A | Better: different municipality, distance of roughly fifteen kilometers as the crow flies (actual fiber length to be measured) | Low: same urban hub as site A, shared regional risks (flooding, power substation, road access) |
| Synchronous replication | Possible (distance under about 20 km) | Possible (very short distance) |
| Certification | Announced as Tier III, **To be checked** | Uptime Institute Tier III (2017), validity **To be checked** |
| Power and network separate from site A | Likely, **To be checked** | **To be checked**: risk of a shared substation |
| Carrier neutrality | Data center of a telecom operator: access for other carriers (second link) must be guaranteed by contract | Same |
| International connectivity | Announced proximity to the 2Africa cable (To be checked) | To be checked |

Recommendation: **Sonatel Rufisque** as first choice for geographic separation, **Yas Diamniadio** as the alternative if the certification and capacity of Rufisque are not confirmed. In both cases, the agreement must guarantee the arrival of at least one carrier other than the data center operator.

### Site C — backup vault (Recommendation)

Site C hosts no production. It receives:

- **encrypted, immutable** copies (object storage with write-once locking, or an immutable backup appliance) fed continuously from A and B;
- **offline** copies (encrypted tapes or disconnected disks) renewed every week and kept in a safe;
- backups of the HSM keys (in encrypted form, split among several custodians);
- a lightweight **arbiter** (quorum witness) to prevent A and B from both believing they are primary if the link between them is cut, if site C's link allows it.

Site C should be outside the Dakar–Diamniadio–Rufisque area if possible (another region), in a State facility or a separate secure facility, to be identified with Sénégal Numérique (**To be checked**). No copy is sent abroad.

## Operating modes per tier

| Tier | Mode | Details (Target) |
|---|---|---|
| Web (static files of the platforms) | Active-active A and B | Served by a web tier behind the WAF, in each site |
| WawID API | Active-active A and B | Stateless containers, at least three instances per site; same code in both sites |

| Tier | Mode | Details (Target) |
|---|---|---|
| Database (PostgreSQL) | Synchronous primary / standby | Cluster managed by Patroni or equivalent; primary in A, local replica in A, at least one **synchronous** replica in B (a transaction is committed only after being written in B); asynchronous replication and continuous archiving of transaction logs (WAL) to C |
| Object storage (biometrics, documents, exports) | Replicated between A and B | S3-compatible (for example MinIO or Ceph), erasure coding within each site, replication between sites; object locking for archives |
| Event bus (Kafka or equivalent) | Replicated | Cluster stretched over A, B and an arbiter, or one cluster per site with replication; choice to be validated |
| Biometrics (ABIS) | Active / standby | According to the capabilities of the selected supplier; galleries replicated in both sites |
| HSM | Pair per site | Signing keys for QR codes, sessions and audit log anchoring; backup encryption keys; keys replicated through ceremonies |
| Orchestration | One Kubernetes cluster (or equivalent) per site | Identical deployments driven from a single configuration repository |
| Identity (OIDC, MFA) | Active-active | Replicated directory and identity provider (To be developed) |
| Global load balancing | DNS with failover and health checks, or a virtual address announced by both sites (anycast or dual-homing) | Short TTLs; automatic failover when a site's health is lost |
| Protection | WAF, anti-DDoS, PKI | WAF in each site; volumetric protection provided by the carriers (To be checked); State or dedicated PKI for server, officer and device certificates |

## Network

| Link | Recommendation |
|---|---|
| Internet for sites A and B | Two different carriers per site (for example two among Sonatel/Orange, Free, Expresso, Yas), separate physical paths; a diversity requirement, without prejudging the choice of carriers |
| Link A ↔ B | Dark fiber or dedicated layer 2 or layer 3 link, over **two separate physical paths**, encrypted; latency measured before synchronous replication is put into service |
| Link to C | Dedicated encrypted link, with enough bandwidth for continuous archiving; offline copies are transported physically under a secure procedure |
| Border posts | MPLS or encrypted VPN to A and B (carrier 1), 4G or VSAT backup (carrier 2); automatic failover |
| Airlines | Internet, through the WAF, on the `POST /api/carrier/messages` gateway with the `X-Carrier-Key` key (Existing); client certificates (mTLS) considered (Recommendation) |

| Link | Recommendation |
|---|---|
| Interpol | I-24/7 connection through the Interpol NCB in Dakar, under the terms defined with Interpol (**To be checked**) |
| WAPIS, FPR, DAF (civil registry, passports) | Private links or VPN with the departments holding them, after agreements (**To be checked**) |
| DGCPT / Treasury | Access for Treasury officers through VPN or the administration's private network; encrypted exchange of reconciliation files |
| Platform administration | Only through a bastion, from the administration network (see section 5) |

## Exposure and domains

Today, the four platforms are served under a single domain, with separate paths (Existing): DPAF space `/dpaf/`, traveler platform `/`, mobile apps `/app/`, airline platform `/compagnies/`, kiosk `/gate/`. In production, each platform gets its own domain (Recommendation):

| Platform | Indicative domain | Exposure |
|---|---|---|
| Travelers (portal, help, e-Visa, eGate pre-enrollment) | `www.<domain>` or `voyageurs.<domain>` | Internet, behind the WAF |
| Mobile apps and their API | `app.<domain>` (page) and `api.<domain>` (public routes) | Internet, behind the WAF |
| Airlines (platform and gateway) | `compagnies.<domain>` | Internet, behind the WAF, rate limiting |
| DPAF space | `dpaf.<domain>` | Private network or VPN only, never on the Internet |
| eGate kiosks | Served by the post server on the post network | Post network only |

The code calls the API through relative paths (`/api/...`): each domain therefore routes `/api/*` to the API tier. Links between platforms and shared resources (`/shared/`) must be checked during the migration. Since the session cookie is bound to the domain, separating the domains also separates sessions between platforms.

## Border posts (edge)

| Item | Target (To be developed) |
|---|---|
| Servers | Two-node cluster per post (AIBD, PDK, ZIG, ROS, KID, KAR); AIBD capacity to be sized for the peak |
| Local data | Encrypted copy of the watchlists, approved e-Visas and CSCA certificate lists, synchronized in under one minute |
| Decision | `public/shared/engine.js` engine run locally; local 1:1 biometric comparison |
| Crossings | Recorded locally then forwarded to the central system (store and forward), with a unique identifier to avoid duplicates |
| Attached devices | Counters, eGates, kiosks, CCTV, plate readers; they talk to the post server, which talks to the central system |

| Item | Target (To be developed) |
|---|---|
| Power | UPS and generator; autonomy sized according to observed outages |
| Network | Two links (main and backup), local firewall, segmentation |

What does not work without a link: real-time queries to external sources (Interpol, WAPIS), 1:N biometric search, reception of new API/PNR messages, knowledge of e-Visas approved or revoked after the cut. These limits are offset by the local copy and by reconciliation when the link returns.

# 3. Backup strategy

## 3-2-1-1-0 rule

| Item | Implementation (Target) |
|---|---|
| 3 copies | Production (A), replica (B), backups (A, B and C) |
| 2 media | Disk (backup storage) and removable media (tape or offline disk) |
| 1 off-site copy | Site C |
| 1 immutable or offline copy | Write-once storage at site C and a weekly offline copy in a safe |
| 0 errors | Automatic verification of each backup (checksums, test restoration); any error opens an incident |

## Schedule

| Data | Frequency | Destination |
|---|---|---|
| PostgreSQL transaction logs (WAL) | Continuous archiving, point-in-time recovery (PITR) | A, B and C |
| Full database | Daily | A and B, copy to C |
| Incremental database | Hourly | A and B, copy to C |
| Object storage (biometrics, documents) | Continuous replication A ↔ B; versioning; daily copy | C |
| Audit log | Daily export of the SHA-256 chain and of the chain head signed by the HSM | C, in addition to the database |
| Configuration (Kubernetes, network, firewall) | At each change, from the configuration repository | A, B and C |
| Offline copy | Weekly | Safe at site C |
| HSM keys | At each key ceremony | Encrypted backup split among custodians, at site C and in a second safe |

### Retention

The data retention period shown in WawID is **5 years** (`retentionDays` setting, 1,825 days, Existing). The applicable legal period is **To be checked** with the CDP and the DPAF. Backups follow the same rule: data purged from production must disappear from backups at the latest when their own retention period expires. The demonstrator applies **no automatic purge**: the purge and archiving job is **To be developed**.

### Encryption and keys

- All backups are encrypted before they leave the server that produces them.
- Backup encryption keys are protected by the HSMs (master key never exported in clear).
- Restoration requires two authorized people (four-eyes principle).

### Restoration tests

| Test | Frequency | Criterion |
|---|---|---|
| Full database restoration in pre-production | Quarterly | Consistent database, duration measured, RPO observed |
| Point-in-time restoration | Quarterly | Return to the requested point in time |
| Restoration from site C (immutable copy) | Twice a year, during drills | Rebuild possible without A or B |
| Verification of the restored audit log | At each restoration | **Chain intact** and chain head consistent with the last HSM signature |

## 4. High availability and disaster recovery

### Failure scenarios

| Scenario | Detection | Decision | Target RTO | Target RPO | Main actions |
|---|---|---|---|---|---|
| Loss of a node (server, container) | Automatic monitoring | Automatic | A few minutes | 0 | Restart or takeover by the other instances; node replacement |
| Loss of a rack or room within a site | Monitoring | Automatic, then operations manager | Under 15 min | 0 | Database failover to the local or remote replica; capacity absorbed by the other site |
| Loss of site A | Monitoring and arbiter | Automatic for the database if the arbiter confirms; otherwise decision by the crisis unit | ≤ 1 h | ≤ 5 min (0 if synchronous replication is healthy) | Promotion of the B replica; DNS or virtual address to B; audit log check; posts informed |

| Scenario | Detection | Decision | Target RTO | Target RPO | Main actions |
|---|---|---|---|---|---|
| Loss of site B | Monitoring | Automatic | No outage (A remains primary) | 0 | Synchronous replication switches to degraded mode (asynchronous to C); alert; B restored |
| Both central sites unavailable | Post monitoring | Crisis unit | Rebuild: to be defined | Last copy received by C | Posts in offline mode; rebuild from C; resynchronization of queued crossings |
| Link loss at a post | Post server, monitoring | Automatic | Failover to the backup link within a few minutes | 0 (queued crossings) | 4G/VSAT backup; otherwise offline mode; resynchronization when the link returns |
| HSM failure | Monitoring | Automatic | No outage (twin HSM) | 0 | Replacement; key resynchronization through a ceremony |
| Ransomware or logical corruption | SOC, SIEM | Crisis unit and security officer | To be defined depending on the extent | Last clean, immutable copy | Isolation; analysis; restoration from an immutable copy; posts in offline mode if needed |
| Power cut at a post | UPS | Automatic | No outage on UPS then generator | 0 | Switch to UPS and generator; clean shutdown if autonomy runs out |

The RTOs and RPOs above are objectives; they are measured during drills and adjusted.

## Who decides

| Decision | Responsible |
|---|---|
| Automatic failover of a component | Monitoring (no human intervention) |
| Manual failover of a central site | WAW Telecom operations manager, after informing the DPAF |
| Activation of the crisis unit | Operations manager or security officer |
| Posts switched to prolonged degraded mode | DPAF (post chief, on instruction from management) |
| Restoration from site C | Crisis unit, with the DPAF's agreement |
| Communication to airlines and the Treasury | Crisis unit |

## Failover of a central site (standard procedure)

1. Confirm the outage (monitoring, health check, confirmation by the arbiter) and open a major incident.
2. Check that the replica at the surviving site is up to date (replication lag zero or known).
3. Promote the replica to primary (automatically or manually) and fence the former primary to avoid two simultaneous primaries.

4. Redirect traffic (DNS or virtual address) to the surviving site; check access to the four platforms and to the airline gateway.
5. Check the **Audit log** (**Chain intact**) and access to the HSMs of the surviving site.
6. Check the resynchronization of the post servers.
7. Inform posts, the DPAF, the DGCPT and airlines according to the communication plan.
8. Record each step and its time.

### Switchback

1. Rebuild or repair the failed site.
2. Resynchronize it as a replica of the site that became primary.
3. Wait for stable synchronous replication.
4. Return to nominal operation during a planned maintenance window (deliberate switchback, never automatic).
5. Write the lessons learned and update the procedures.

### Drills

- **At least two recovery drills per year**: actual failover from A to B, then back.
- One annual full restoration drill from site C.
- One annual link-cut drill at at least one land post.
- Each drill results in a report shared with the DPAF.

### Runbooks to be written

- Database failover and switchback.
- DNS or virtual address failover.
- HSM replacement and key ceremony.
- Full restoration and point-in-time restoration.
- Rebuild from site C.
- Offline mode of a post and resynchronization.
- Ransomware response.
- Rotation of device and airline keys.
- Crisis communication.

## 5. Security and compliance

| Area | Measure (Target) |
|---|---|
| Segmentation | Separate zones: Internet exposure (WAF, public web), API, data, administration, links to posts, links to partners; filtering between zones |
| Administration access | Single bastion per site, strong authentication (MFA), nominative accounts, session recording, time-limited privileges |
| User identity | OIDC, MFA and PKI officer cards; MFA is **To be developed** (the demonstrator uses username and password) |
| Devices | Replacement of the shared `WAWID_GATE_KEY` key with per-device certificates (mTLS), **To be developed** |

| Area | Measure (Target) |
|---|---|
| Security monitoring | 24/7 SOC and SIEM, correlation of application, system, network and HSM logs |
| Vulnerabilities | Continuous scanning of images and systems, patches according to criticality, penetration tests before go-live and at least once a year |
| Audit log | SHA-256 chain (Existing) periodically anchored by an HSM signature (To be developed) |
| Personal data | CDP formalities before any production use; record of processing activities; procedure for access and rectification rights |
| Physical security | Access control for rooms and racks, CCTV, intervention log, locked racks for WawID equipment |
| Personnel | Clearance of people with privileged access (procedure **To be checked** with the authorities); confidentiality undertaking |
| Key ceremonies | Generation, backup and rotation of keys in the presence of witnesses, signed minutes, multiple custodians |

## 6. Deployment phases

Durations are **indicative** and to be confirmed at the end of phase 0. They are longer than those of the proposal note (`docs/PROPOSITION-REMPLACEMENT-SECURIPORT.md`), which did not include building the high-availability infrastructure. Phases 1 and 2 run in parallel.

| Phase | Content | Entry criteria | Exit criteria | Indicative duration |
|---|---|---|---|---|
| 0. Scoping and legal | Contract; CDP formalities; agreement with Sénégal Numérique (site A) and with the commercial data center (site B); choice of site C; collection mandate for the security fee if the `OPERATEUR` flow is selected; agreements with the file holders | Launch decision | Agreements signed; CDP formalities initiated; architecture validated | 1 to 3 months |
| 1. Build of sites A, B and C | Racks, power, network, A ↔ B links, carriers, firewalls, WAF, HSMs, Kubernetes, PostgreSQL, object storage, backups, SOC | Phase 0 completed; hardware delivered | Infrastructure tests passed, including an A → B failover and a restoration from C | 3 to 6 months |
| 2. Application migration | Move from the Netlify demonstrator to the sovereign stack (see the table below) | Priority developments started | Functional acceptance in pre-production; load test; penetration test | 3 to 6 months, in parallel with phase 1 |
| 3. AIBD pilot | A few counters and eGates at arrivals and departures, in parallel with the system in place; AIBD post server; gateway open to volunteer airlines; security fee reconciliation | Phases 1 and 2 validated; CDP formalities completed; officers trained | Pilot acceptance; no blocking incident during the observation period; failover drill passed in real conditions | 2 to 3 months |

| Phase | Content | Entry criteria | Exit criteria | Indicative duration |
|---|---|---|---|---|
| 4. Rollout in waves | Wave 1: full AIBD, ZIG, PDK. Wave 2: ROS, KID, KAR (offline mode essential) | Pilot review; post servers installed; links doubled | Acceptance per post, including a link-cut test; decommissioning of the previous system under the contractual clauses | 1 to 2 months per wave |
| 5. Operations (MCO) | 24/7 monitoring, maintenance, drills, enhancements | Go-live report | Annual review | Ongoing |

## Migration from the demonstrator to the sovereign stack (phase 2)

| Item | Demonstrator (Existing) | Target | State |
|---|---|---|---|
| API | Single function `netlify/functions/api.mts` routed on `/api/*` | Same code and same routes in a Node.js 22 container, behind a gateway; the local server `dev-server.mjs` already shows that the function runs outside Netlify | To be developed (adapter and container image) |
| Storage | Netlify Blobs through `netlify/lib/store.mts`: one collection = one JSON document rewritten on each write | PostgreSQL (transactions, tables partitioned by month) and object storage; `store.mts` replaced by an SQL repository; end of the global `/api/data` load | To be developed |
| Secrets | Netlify environment variables (`SESSION_SECRET`, `WAWID_GATE_KEY`, `WAWID_CARRIER_KEYS`, connector tokens) | Secrets vault and HSM; separate keys for sessions and for QR codes | To be developed |
| Static files | `public/` published by Netlify | Web tier in each site, behind the WAF, one domain per platform | To be developed (configuration) |
| Security headers | `netlify.toml` | Reproduced on the reverse proxy and the WAF | To be developed (configuration) |
| Demo dataset | Created automatically if the database is empty (`netlify/lib/seed.mts`) | Disabled in production | To be developed |
| Audit log | SHA-256 chain in storage | Append-only table, HSM anchoring, export to C | To be developed (anchoring) |
| Identity | scrypt password, signed 12-hour session | OIDC, MFA, PKI officer cards | To be developed |
| Offline mode | None | Post server with store and forward | To be developed |

| Item | Demonstrator (Existing) | Target | State |
|---|---|---|---|
| eGate kiosks | `/gate/` with the `X-Gate-Key` header | Served by the post server; per-device certificates | To be developed |
| NFC bridge | `tools/nfc-bridge.mjs`, origin allowed by `NFC_BRIDGE_ORIGIN` | `NFC_BRIDGE_ORIGIN` limited to production domains (`dpaf.<domain>`, kiosk domain) | Configuration |
| Mobile app | `mobile/`, default API `https://wawid-waw-telecom.netlify.app` | Built with `--dart-define=WAWID_API=https://api.<domain>` | Configuration |
| Airline gateway | `POST /api/carrier/messages` | Same contract, exposed on `compagnies.<domain>` behind the WAF | Configuration |
| Data | Fictitious | No takeover from the demonstrator; possible takeover from the system in place under the contractual clauses | To be checked |

### Acceptance tests

| Test | Phase | Success criterion |
|---|---|---|
| Load test | 2, then before each wave | 10 checking transactions per second sustained and 50 in bursts; AIBD peak of 15,000 travelers per hour carried by **a single** site |
| Failover test A → B and back | 1, 3, then twice a year | RTO ≤ 1 h; RPO met; audit log intact |
| Restoration test (pre-production and from C) | 1, then every quarter | Full restoration successful; duration and loss measured |
| Penetration test | 2, before the pilot, then every year | No open critical or high vulnerability |
| Link cut at a post | 3 and 4 | Checks continue; crossings resynchronized with no loss or duplicate |
| Loss of an HSM | 1 | No interruption of signing |
| Functional acceptance | 2 and 3 | Acceptance table of the *Installation guide — Senegal* |

## 7. Environments

| Environment | Location | Data | Use |
|---|---|---|---|
| Production | Sites A and B (active), C (vault) | Real | Operations |
| Pre-production | Site B, isolated from production | Synthetic or anonymized | Validation of releases, load and restoration tests, drills |
| Test and training | Site B or a dedicated environment | Fictitious | Acceptance, officer training, airline trials |
| Development | WAW Telecom | Fictitious | Development, `npm test` |

| Environment | Location | Data | Use |
|---|---|---|---|
| Netlify demonstrator | Netlify, outside the national territory | Fictitious only | Demonstrations; no real personal data |

Each environment has its own secrets, keys and accounts. A release is deployed to production only after validation in pre-production.

# 8. Operations

## Monitoring

- **24/7 network operations center (NOC)**, coupled with the SOC.
- Health checks of both sites, replication, each post's links, HSMs, backups and certificates.
- The status of post devices is also shown in **System monitoring** in the DPAF space (Existing for display; real reporting To be developed).
- Capacity and performance dashboards, alert thresholds and on-call duty.

## Service levels to negotiate

These items are to be negotiated with Sénégal Numérique and the commercial data center; no value is set in this plan:

- availability of power and cooling;
- on-site intervention and emergency access times;
- availability and restoration time of carrier links;
- anti-DDoS protection and filtering capacity;
- physical security, access control and visitor log;
- notification of incidents and planned maintenance;
- reversibility and exit conditions;
- penalties for failures.

## Capacity, patches and changes

- **Capacity**: quarterly review of actual load (crossings, e-Visas, API/PNR messages, biometrics) against the sizing; each site must be able to carry the peak alone.
- **Patches**: update site by site (B then A), without interruption thanks to active-active; critical patches applied urgently under the change procedure.
- **Changes**: change advisory board with the DPAF; planned and announced maintenance windows; every change is first applied in pre-production.
- **Planned maintenance**: preferably during off-peak traffic hours, announced in advance to posts, airlines and the Treasury.

## Responsibility matrix (RACI)

R: responsible; A: accountable; C: consulted; I: informed. Proposed allocation, **To be checked** in the agreements.

| Activity | WAW Telecom | DPAF | Sénégal Numérique | Commercial DC | DGCPT | Airlines |
|---|---|---|---|---|---|---|
| Hosting of site A (power, room, access) | C | I | R/A | — | — | — |
| Hosting of site B | C | I | — | R/A | — | — |
| WawID infrastructure and platform | R/A | C | C | C | — | — |
| Backups and restorations | R | A | C | C | — | — |
| Decision to fail over a site | R | A | I | I | I | I |
| Post operations (procedures, degraded mode) | C | R/A | — | — | — | — |
| Security (SOC, vulnerabilities) | R | A | C | C | — | — |
| CDP formalities | C | R/A | — | — | — | — |
| Security fee (settings, collections) | R | I | — | — | A | C |
| API/PNR transmission | C | A | — | — | — | R |
| Recovery drills | R | A | C | C | I | I |

## 9. Bill of materials per site

Equipment types and quantities **to be sized** during the detailed study; no prices. The minimum quantities given follow from the redundancy principles.

| Equipment | Site A | Site B | Site C | Each post |
|---|---|---|---|---|
| Racks | To be sized | To be sized | 1 or 2 | 1 rack or cabinet |
| Routers (two carriers) | 2 | 2 | 1 or 2 | 1 (+ 4G/VSAT router) |
| Firewalls | High-availability pair | Pair | 1 or pair | 1 |
| Switches | At least a pair | At least a pair | 1 or 2 | 2 |
| Load balancers and WAF | Pair | Pair | — | — |
| Kubernetes servers | 3 control-plane nodes + worker nodes to be sized | Same | — | — |
| PostgreSQL servers | At least 2 | At least 2 (with separate pre-production) | — | — |
| Object storage | At least 4 nodes (erasure coding) | At least 4 nodes | Immutable storage to be sized | — |

| Equipment | Site A | Site B | Site C | Each post |
|---|---|---|---|---|
| Event bus | 3 nodes | 3 nodes | Possible arbiter | — |
| ABIS servers (biometrics) | According to supplier | According to supplier | — | — |
| HSM | 2 | 2 | Key backup (safe) | — |
| Backup | Backup server | Backup server | Immutable appliance + offline tapes or disks + safe | — |
| Bastion and monitoring | 2 bastions, SIEM collectors | 2 bastions, SIEM collectors | — | — |
| Post servers | — | — | — | 2 nodes |
| Power | Provided by the host (To be checked) | Provided by the host | Depending on the site | UPS + generator |

## 10. Risks and mitigations

| Risk | Consequence | Mitigation |
|---|---|---|
| Certification or capacity of a data center not confirmed | Actual availability below the objective | Technical audit before signature; capacity clause; certified site B |
| Sites A and B too close (same area, same substation) | Simultaneous loss of both sites | Prefer a separate site B (Rufisque); check power feeds; distant site C |
| Cut of the A ↔ B link | Synchronous replication interrupted; risk of two primaries | Two fiber paths; arbiter at site C; manual failover if the arbiter is unreachable |
| Dependence on a single carrier | General network outage | Two carriers per site and per post |
| Delay of the posts' offline mode | Land posts stopped during an outage | Development priority; written manual procedure; land wave conditional on its validation |
| Ransomware | Encryption of production data and online backups | Immutable and offline copies; segmentation; administrator MFA; drills |
| Loss or compromise of keys | Unable to verify QR codes, restore or prove integrity | HSM pairs; split key backup; ceremonies |
| CDP formalities or security fee texts not completed | Production blocked | Started in phase 0; `TRESOR` flow usable pending the text for the `OPERATEUR` flow |
| Procurement lead times (HSMs, servers, fiber) | Delay of phases 1 and 4 | Orders as soon as phase 0 ends; spare hardware |
| Insufficient operations skills | Poorly handled incidents | Training, written procedures, drills, skills transfer |
| Power cuts at posts | Equipment stops | UPS, generators, regular tests |

| Risk | Consequence | Mitigation |
|---|---|---|
| Load above assumptions | Degraded response times | ×5 margin, quarterly review, horizontal scaling |

## 11. Existing, target and to be developed

| Topic | Existing (demonstrator) | Target | To be developed |
|---|---|---|---|
| Hosting | Netlify, outside the national territory | Sites A and B in Senegal + vault C | Building the sites |
| Storage | Netlify Blobs, one collection per JSON document | Replicated PostgreSQL and object storage | PostgreSQL storage layer |
| Availability | That of Netlify, without sovereign commitment | 99.95% or more, two active sites | Infrastructure, procedures, drills |
| Backups | No dedicated backup | 3-2-1-1-0 rule | Full implementation |
| Keys and secrets | Environment variables | HSM pairs, secrets vault | HSM integration |
| Identity | Password, 12-hour session | OIDC, MFA, PKI cards | MFA, OIDC |
| Posts | Browser connected directly to the central system | Post server, offline mode | Post server and resynchronization |
| Audit log | Verifiable SHA-256 chain | Chain anchored by the HSM, exported to C | Anchoring and export |
| Airline gateway | `POST /api/carrier/messages`; a resend creates a new message but merges the passengers of the same flight | Same contract, behind the WAF | Explicit idempotency key and resend guidelines |
| Security fee | `OPERATEUR` flow by default ( `settings.redevance.circuit` ); `TRESOR` flow available | Flow set by the texts | Real invoices; text and mandate if `OPERATEUR` |
| Retention | 5 years displayed, no purge | Compliant purge and archiving | Purge job |